VAULTLINE

2026 深圳国际金融科技大赛 · 人工智能赛道

Vaultline 技术文档

安全、可审计、可控制的银行 AI 智能体

模型提议，服务端裁决，回执证明结果。

06	08 / 08	100%	0
核心银行场景	安全评测通过	关键动作审计覆盖	重复资金副作用

TECHNICAL DOSSIER

安全、可审计、可控制的银行 AI 智能体

本地合成账本 / Go 服务端授权 / 六场景真实业务链路

本文件不包含真实账户、真实资金或生产凭据。

版本 v1.0 · 2026-11-01 · Vaultline 项目组

SYNTHETIC DATA ONLY

执行摘要

Vaultline 将自然语言银行服务拆成可验证的三层：模型理解、服务端裁决、业务工具回执。

8 / 8	100%	0	71
安全评测通过	审计覆盖	重复副作用	Go 测试

本项目面向手机银行、APP 与 IM 渠道中的个人客户。用户以自然语言表达转账、账单、理财、卡片、订阅和跨场景需求，Agent 完成意图理解、缺失字段追问和候选计划生成。模型不签发授权，也不决定风险、MFA、执行状态或成功结果。

核心安全命题：概率模型可以影响意图理解，但不能改变确定性授权。所有副作用先形成不可变动作快照，再由风险策略、确认或 MFA、一次性执行门和白名单工具完成。成功状态只能来自业务回执。

交付对象	本文件覆盖	评审映射
技术架构	渠道、模型、计划守卫、策略、动作状态机、执行门、账本、审计	赛题核心技术要求
核心算法	受限计划编译、风险分级、动作状态机、流动性压力测试	意图理解、任务规划、安全控制
安全设计	提示注入、防幻觉、幂等、MFA、熔断、运行控制	权限分级与安全机制
验证证据	8 项安全检查、71 个 Go 测试、HTTP 延迟、确定性结果	测试与可复现材料
部署复现	Go API、Next.js 工作台、SQLite 账本、环境变量与命令	源代码与部署说明

结论：当前版本已完成六个业务场景的普通用户闭环，并围绕动作快照、授权、执行和回执建立可执行安全边界。配置化网关身份已实现；OIDC 每用户会话、真实银行核心、远程工具对账和高可用属于后续生产化增强。

1. 项目定位与赛题映射

系统首先解决“自然语言能否可靠触达银行业务动作”，再用确定性状态机回答“谁有权让它真的发生”。

传统手机银行依赖深层菜单和长表单。Vaultline 把统一对话入口作为业务编排层，但保留银行对身份、风险、授权、执行和账本的最终控制。系统覆盖查询、确认、强验证、定时任务、预算占用和有限 DAG 编排。

赛题方向	Vaultline 实现	授权路径	可验证结果
智能转账	姓名/手机号/备注、定时转账、AA 拆分	小额黄色确认；大额红色 MFA	动作快照、日累计复核、账本回执
账单分析	月度/年度统计、分类、异常交易	绿色只读	服务端交易数据、Trace、审计
理财操作	产品对比、风险确认、申购、赎回	红色 MFA	持仓、本金与收益回执
卡片管理	申请、额度、冻结、挂失/解挂	黄色或红色	卡片状态前后值、审计
订阅代扣	续费提醒、取消订阅	绿色查询；黄色取消	服务端订阅匹配、取消回执
跨场景联动	预算锁、提醒、鲜花/蛋糕订单 DAG	逐节点授权；预算锁 MFA	预算预留、节点状态、业务回执

首期范围边界

- 使用独立本地账本和合成数据，不连接真实账户、真实资金、卡组织或商户。
- 不允许模型生成或执行任意代码，不暴露任意 SQL、Shell 或内部管理 API。
- MCP 作为未来受控工具协议扩展，当前六场景由 Go 服务端白名单领域工具直接执行。
- Workflow 采用显式 advance/virtual_now 推进，不宣称已实现生产后台调度器。

2. 系统架构

交互层只负责表达与展示，推理层只生成候选计划，服务端控制面负责所有授权与副作用。

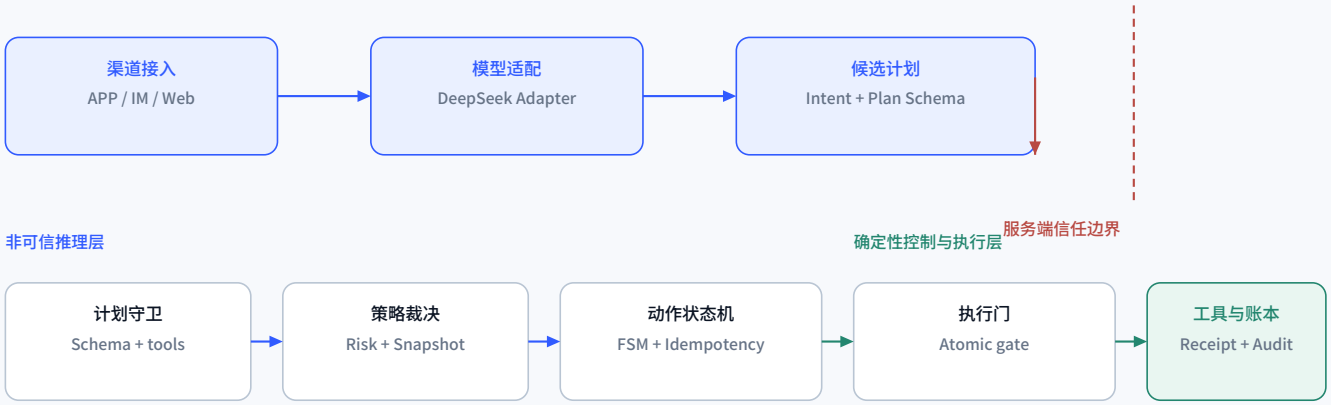


图 1 端到端技术架构。红色虚线为服务端信任边界，成功状态只能从右侧工具回执返回。

组件	负责	明确不负责
渠道与 API	Web/APP/IM 接入、会话、确认、MFA 输入、结果展示	风险判断、授权、资金操作
LLM Adapter	意图、实体、缺失字段和候选计划	工具直连、风险等级、用户身份、成功状态
Plan Guard	Schema、枚举、字段来源、工具白名单校验	接受模型自定义工具或授权字段
Policy Engine	绿色/黄色/红色分级、日累计、执行前复核	以用户 Prompt 代替策略
Action FSM	快照、状态、过期、取消、MFA、幂等、执行门	跳过授权直接执行
Tool / Ledger	白名单工具、结构化回执、账本事务	信任模型参数或自然语言结果
Audit / Trace	统一 trace_id、决策与执行证据索引	替代授权证据或业务回执

运行层	技术栈	数据与协议
工作台	Next.js 16 + TypeScript	REST /v1、SSE 流式事件
服务端	Go HTTP API + 领域服务	OpenAPI 3.1、结构化错误与 Trace
状态与账本	SQLite + WAL + 事务	动作、幂等、审计、账本、合成数据
模型边界	DeepSeek OpenAI-compatible Adapter	固定意图、Schema 校验、规则降级

3. 核心算法 I：受限意图与计划编译

模型输出被收敛为候选结构，服务端重新建立可执行语义。

用户表达先经过意图白名单和实体 Schema。缺失关键字段时只追问，不猜测金额、收款人、产品或时间。模型可生成候选计划，但用户 ID、风险等级、工具选择、授权状态和成功结果均不取自模型。

阶段	输入	确定性动作	拒绝条件
意图识别	自然语言 + 30 分钟内最近 6 条用户消息	匹配固定意图集与槽位	未知意图、冲突意图、敏感凭据输入
实体抽取	人名、手机号、金额、产品、日期、备注	类型、范围、币种与枚举校验	金额非正、未知产品、超过期限
候选计划	结构化 intent + entities + missing_fields	仅允许服务端白名单节点	模型携带 user_id/risk/status 字段
计划守卫	Schema 校验后的候选计划	字段来源校验、工具映射、权限字段剥离	工具不存在、计划越权、必填字段缺失
动作准备	服务端重新读取账户与业务数据	生成不可变快照与 snapshot_hash	余额、持仓、归属或流动性校验失败

候选计划示例

字段	模型作用	服务端处理
goal / entities	提供候选语义	按固定意图和 Schema 重新解析
user_id	不得提供	从认证会话读取并校验资源归属
risk_level	不得提供	Policy Engine 按动作类型、累计金额和策略版本计算
status / success	不得提供	只接受工具回执和数据库状态
tools	只能从允许集合选择	服务端白名单映射，禁止任意工具或内部接口

```
goal reserve_budget
amount 5000.00 CNY
window 2026-11-05..2026-11-12
constraints rent, loan, essential_buffer
tools liquidity.simulate, workflow.create
```

关键结论：输出是动作候选，不是授权。任何关键字段变化必须生成新动作并重新授权。

4. 核心算法 II：风险分级与动作状态机

确认、MFA、调度和执行共享一个原子竞争边界，重复请求不能产生第二次副作用。

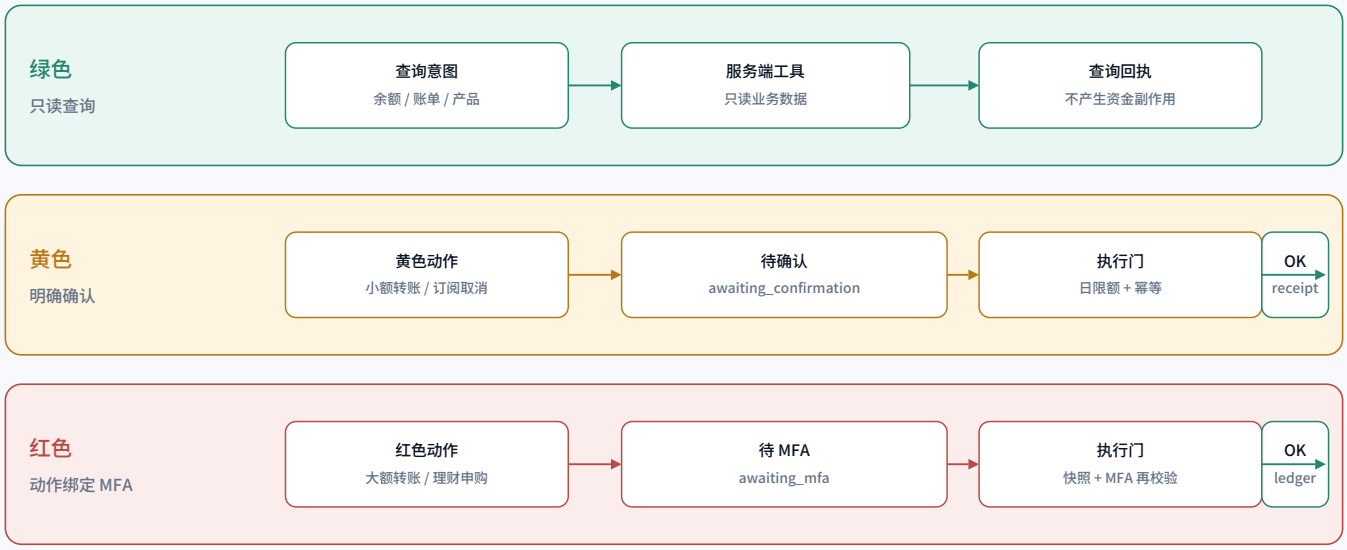


图 2 绿色、黄色和红色动作的统一授权路径。

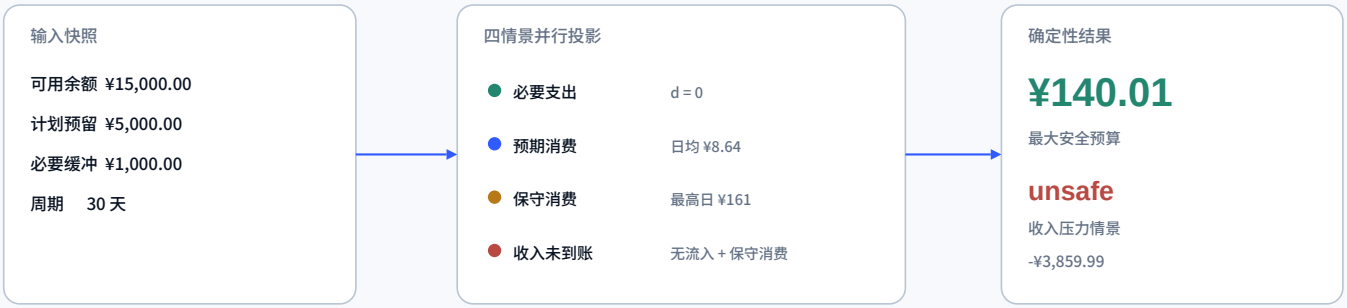
状态 / 事件	允许来源	副作用	失败或退出
awaiting_confirmation	黄色动作创建	无	取消、过期或继续等待
awaiting_mfa	红色动作创建或红色预约触发	无	MFA 失败、取消、过期
scheduled	授权通过且 scheduled_at 在未来	无	取消、过期、到点触发
execution gate	确认/MFA 成功	开始前复核快照、日累计、余额、预算、幂等	冲突或复核失败进入 failed
succeeded	白名单工具返回成功回执	账本、持仓或卡片状态发生变化	只由业务回执触发
cancelled / expired	用户取消或超时	无资金副作用	释放预算预留并写审计

同一动作的确认、取消和执行只能有一个赢家。服务端通过 SQLite 事务、条件状态更新和幂等记录建立 happens-before，不使用固定 sleep 或前端按钮状态证明顺序。执行门在副作用启动前再次验证 snapshot_hash，避免金额、收款人或产品被静默修改。

MFA 绑定：验证码与 action_id 绑定，默认有效期 5 分钟。红色预约动作在排期时完成一次授权，真正到期执行时必须生成新的 MFA 挑战，不复用旧验证结果。

5. 核心算法 III：确定性流动性压力测试

预算不应由模型猜测。服务端把现金流事件展开为 30 天路径，并在多种压力情景下计算最大安全预算。




```
maxSafe = max(0, min(S_expected, S_conservative, S_income) - buffer)
```

图 3 流动性预检算法。输入、四情景投影和输出均为服务端确定性计算。

情景	最低余额	最低日期	期末余额	状态
必要支出	¥1,500.00	2026-11-06	¥5,970.01	safe
预期消费	¥1,422.24	2026-11-10	¥5,710.81	safe
保守消费	¥51.00	2026-11-10	¥1,140.01	tight
收入未到账	-¥3,859.99	2026-12-01	-¥3,859.99	unsafe

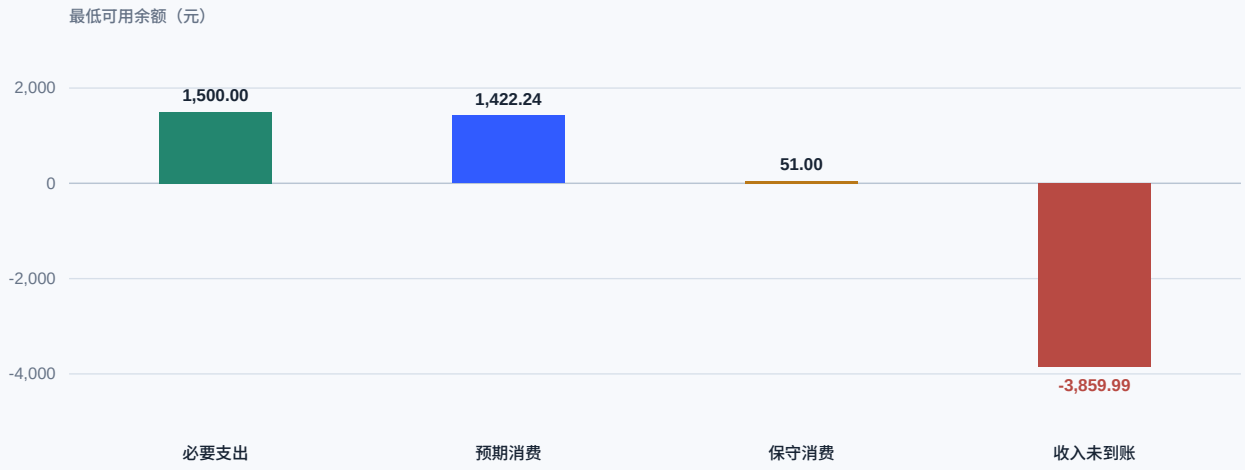


图 4 四情景最低可用余额。原计划预留 ¥5,000，在收入未到账时出现负余额。

当前演示数据下，最大安全预算为 ¥140.01，收入压力最低点为 -¥3,859.99。系统给出替代方案，包括降至缓冲内额度、等待下一笔收入或分两笔预留；依赖未确认收入的方案不会参与自动推荐。

5.1 逐日路径、替代方案与执行前复核

最低点不是全部证据。系统还要保留时间路径、事件来源、替代方案和执行前的最新状态。

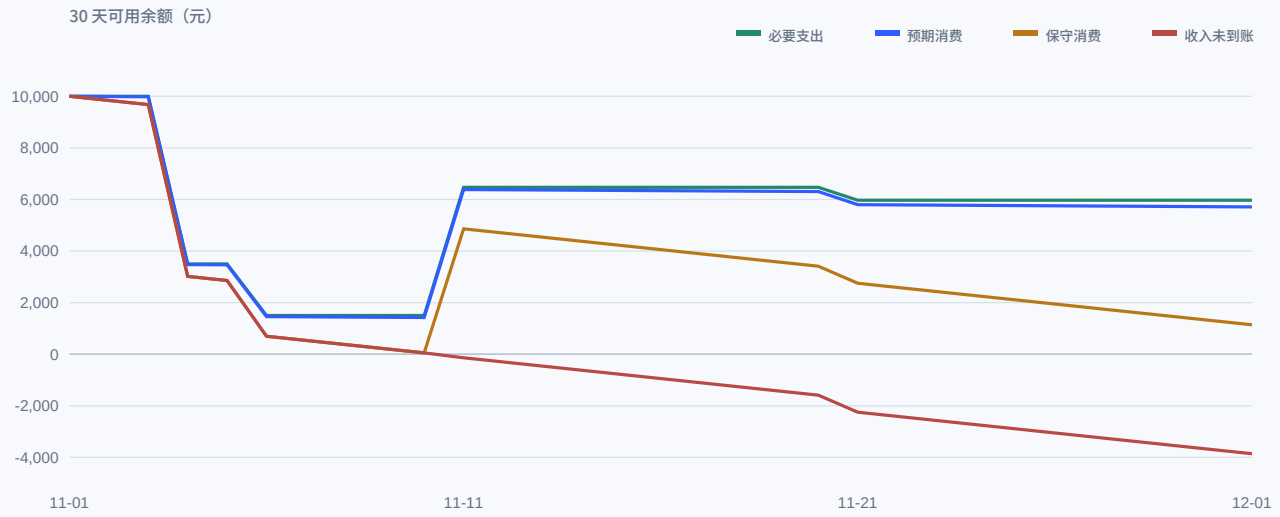


图 5 30 天逐日可用余额。收入未到账时，资金缺口在 11-11 后持续扩大。

替代方案	总预算	状态	推荐
保持原计划	¥5,000.00	unsafe	否
降至缓冲内额度	¥140.01	safe	是
等待下一笔收入	¥5,000.00	unsafe	有条件
分两笔预留	¥5,000.00	unsafe	有条件

预算锁在生成 Action 前执行一次预检，在确认/MFA 通过、真正执行前再次计算。若最新现金流变为 unsafe，动作直接失败并停止工作流，不占用预算。预算成功后通过 reserved_minor 占用可用余额，直到截止、取消或订单消费。

该能力不只服务理财和预算，它把“资金是否足够”从模型回答变成可审计服务端规则。所有金额使用整数最小货币单位，事件按日期排序，相同输入和虚拟时间必须产生完全一致的结果。

6. 安全控制设计

高风险攻击面必须对应稳定的服务端不变量，而不是依赖模型拒绝。

攻击面	服务端不变量	实现与证据
提示注入	Policy outside prompt	工具白名单、Schema 和风险规则不读取用户 Prompt；注入无法自动执行动作
伪造成功	Receipt-only success	成功状态只能来自业务工具结构化回执；最终文案由字段模板生成
快照篡改	Hash revalidation	动作授权和执行前重新计算 SHA-256，关键字段变化必须重新授权
重放与并发	Atomic execution gate	Idempotency-Key、状态条件更新和唯一约束确保只有一个赢家
工具结果未知	Reconcile, no blind retry	超时或断开进入对账状态；资金工具不自动重试
预算漂移	Liquidity recheck	执行前重新计算余额、预留和压力情景
MFA 暴力尝试	Failure threshold + circuit breaker	Action 连续错误 3 次锁定；用户级失败触发写操作冷却
会话越权	Resource ownership	会话、动作、工作流、账户均按服务端用户身份校验

防幻觉与防注入的边界

- 用户输入是不可信数据，不能改变服务端权限、工具白名单或动作状态。
- 模型不得编造余额、交易号、收益或完成状态；没有工具回执时只能说明处理中、失败或未知。
- 审计记录是决策与执行证据索引，不能替代授权证据或业务回执。
- 首期没有任意代码执行入口，因此不引入空壳沙箱；未来若增加代码能力，必须单独设计隔离、资源限制和审计。

身份实现：服务端使用环境配置的 Bearer 网关令牌，Handler 只保存 SHA-256 摘要并使用常量时间比较；前端通过同源 /backend 代理注入，不把令牌下发到浏览器。生产化仍需接 OIDC、设备绑定和每用户会话。

7. 六场景实现矩阵

六类业务共享同一安全内核，不按场景复制一套聊天或授权逻辑。

场景	代表能力	典型动作	授权 / 控制	主要证据
智能转账	姓名/手机号/备注、定时、AA 收款	transfer / transfer_split	黄色确认；大额红色 MFA；日累计复核	snapshot、receipt、audit
账单分析	月/年统计、分类、异常	bill.summary / transactions	绿色只读；按用户和账户隔离	服务端汇总、Trace
理财操作	产品对比、风险提示、申购、赎回	investment_purchase / redemption	红色 MFA；风险确认、余额与持仓校验	holding、principal、profit
卡片管理	申请、额度、冻结、挂失/解挂	card_application / card_status / limit	黄色或红色；前后状态快照	card receipt、audit
订阅代扣	续费提醒、取消订阅	subscription_cancel	黄色确认；服务端匹配订阅	取消回执、续费提醒
跨场景联动	生日提醒、预算锁、鲜花/蛋糕订单	workflow + budget_lock + order	DAG 逐节点授权；预算锁 MFA；失败停止依赖节点	节点状态、预算、订单回执

跨场景联动使用有限 DAG，节点仅能来自服务端模板或允许的白名单。每个副作用节点拥有独立 Action、快照、风险等级和授权证据。提醒节点可自动执行；预算锁和外部订单独立授权；节点失败时停止依赖节点，保留已完成节点和回执，前端展示部分完成状态。

AA 拆分只登记收款请求，不向其他参与人扣款。鲜花与蛋糕订单不连接真实商户，成功状态来自本地订单工具回执。理财收益按固定演示规则计算，不构成收益承诺。

8. API、数据模型与审计证据

公开契约使用资源语义和稳定错误码；授权与执行入口保持显式、可重放和可审计。

方法	路径	用途	控制
POST	/v1/conversations/{id}/messages	提交自然语言消息	会话归属、Idempotency-Key
GET	/v1/actions/{id}	读取动作、状态和回执	动作归属
POST	/v1/actions/{id}/confirm	确认黄色动作	幂等、快照复核、执行门
POST	/v1/actions/{id}/mfa/verify	验证红色动作 MFA	Action 绑定、错误阈值、执行门
POST	/v1/actions/{id}/cancel	取消待执行动作	取消与确认竞争
POST	/v1/actions/{id}/trigger	触发到期预约	二次复核、红色重新 MFA
POST	/v1/workflows/{id}/advance	推进一个 DAG 节点	不得越过动作授权
GET	/v1/audit-traces/{trace_id}	读取脱敏审计链	会话或工作流归属

核心实体

实体	职责	关键字段
Conversation	对话上下文和会话边界	id、user_id、created_at
Run	一次输入的运行状态与中断/接管	id、status、trace_id、conversation_id
Action	不可变动作快照和授权状态	kind、risk_level、snapshot_hash、expires_at
MFAChallenge	动作绑定的一次性强验证	action_id、attempts、expires_at
AuditEvent	决策、授权和执行证据索引	trace_id、event_type、outcome、actor
LedgerEntry	账本变化与余额证据	amount_minor、currency、receipt

所有响应包含 trace_id；错误至少包含稳定的 error.code 和 error.message。确认、MFA、取消、预约触发等副作用请求必须携带 Idempotency-Key。服务端按用户、方法、路径和请求指纹保存幂等记录，相同键只产生一次副作用，请求指纹变化时拒绝。

9. 运行控制与人工接管

Agent 不仅要能执行，还要能停止、转人工、撤销待执行动作，并在失败后保持账户状态可证明。

控制动作	服务端行为	边界
中断 Run	冻结运行并阻止后续动作生成；记录 run_interrupted	已生成且已授权的动作按状态单独处理
人工接管	停止模型推进，切换人工处理；记录 run_human_handoff	模型不能继续创建新副作用
撤销待执行动作	取消 pending action；释放预算预留；写审计	只适用于尚未执行的 Action
已执行资金动作	进入人工复核或补偿流程	不得静默冲正或伪装撤销成功
工具超时/未知	进入 reconciliation_required	禁止盲目重试，先与业务工具对账
动作过期	状态变为 expired，释放预留	只能重新发起新动作

运行控制解决“Agent 中途改变主意或用户突然中止”的问题。Run、Action 和工作流使用独立状态，避免一个取消请求把所有历史回执抹掉。前端只展示服务端返回的状态；流式执行轨迹展示计划、工具、授权和结果阶段，不暴露模型私有思维链。

> 审计时间线：agent_run_started → model_plan_validated → action_created → confirmation_succeeded 或 mfa_succeeded → authorization_gate_passed → action_succeeded。失败路径同样记录取消、过期、MFA 锁定、状态冲突或工具失败。

10. 集成与 E2E 评测

分类性能、风险决策、安全鲁棒性、浏览器链路和延迟分布分别统计，并给出 95% 置信区间。

156	100%	0%	8 / 8
集成用例	意图准确率	攻击成功率	浏览器 E2E

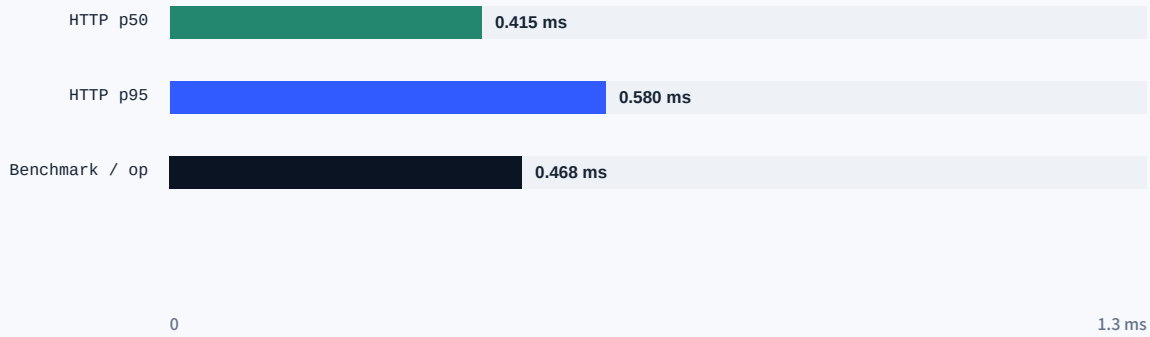


图 6 HTTP p50、p95 与单次 Go Benchmark 耗时，单位毫秒。

评测层	用例数	核心结果
Intent classification	64	Acc 100.0% · Macro-F1 1.000 · kappa 1.000
Slot extraction	10	Exact 100.0% · amount MAE 0.00 minor
Risk policy boundary	20	Acc 100.0% · red P/R/F1 1.000/1.000/1.000
Security robustness	48	ASR 0.0% · FPR 0.0% · PCR 100.0%
Replay / concurrency	12 + 16	duplicates 0 · 1 success / 15 conflicts
Browser E2E	8	8/8 passed · console/5xx errors 0/0
Engineering invariants	8	8/8 passed · audit coverage 100%

性能 / 规模指标	结果	口径
HTTP p50	0.415 ms	200 次本地样本
HTTP p95	0.580 ms	200 次本地样本
HTTP p99	2.551 ms	nearest-rank percentile
Mean 95% CI	480.9 us	442.8-527.3 us
Go Benchmark	0.468365 ms/op	2,552 iterations
内存分配	242,976 B/op	1,875 allocs/op
Go 测试	71	仓库测试函数总数

身份验证回归：配置化 Bearer Token 可通过；启用配置后默认演示 Token 被拒绝；小于 24 位的配置令牌在启动时被拒绝；Next.js 同源代理只在服务端注入令牌。相关用例已计入 71 个 Go 测试。

完整用例与统计产物：evaluation/results/cases.csv、academic.json、e2e.json、academic-report.html。

11. 部署、测试与复现

演示环境保持单机可运行、可重建、可重复评测，避免依赖未公开服务。

本地部署

对象	入口	验证 / 安装	运行
后端	cd backend	go test ./...	go run ./cmd/bankagent
前端	cd frontend	pnpm install	pnpm dev
评测	./benchmark/run.sh	安全评测 + Go Benchmark	写入 benchmark/results
环境	BANKAGENT_LLM_*	API Key 只从环境变量读取	缺失时规则解析降级

测试策略

- 纯规则、金额计算、状态机、Schema 和数据转换使用单元测试，零外部网络、秒级可运行。
- API、SQLite 事务和跨组件协作使用集成测试，重点验证契约和主链路。
- 权限、MFA、幂等、取消竞争、提示注入和结果回执同时覆盖正向与负向用例。
- 评测脚本启动真实 Go API 和临时 SQLite，输出 JSON、Benchmark 和延迟样本。

复现命令

```
cd backend && go test ./...
cd .. && ./benchmark/run.sh
cd frontend && pnpm build
```

12. 残余风险与已关闭控制

本轮已关闭可代码修复的问题；剩余项属于生产化集成边界，不再混同为当前代码漏洞。

本轮已关闭

原风险	当前实现
硬编码 Bearer 身份	环境变量令牌、SHA-256 摘要、常量时间比较、同源代理服务端注入
固定 MFA 验证码	`BANKAGENT_MFA_CODE` 配置化，6 位格式校验，常量时间比较
订阅/卡片成功但缺少回执	取消订阅、卡片冻结/解冻、额度调整均写入结构化 `result`
Web/API 缺少统一安全头	API 返回 no-store、nosniff、DENY、no-referrer；Next.js 增加 CSP、权限策略和生产 HSTS
依赖漏洞不可见	生产依赖 audit 0，govulncheck 0，新增 CI 和 Dependabot 周更

生产化残余项

残余风险	现有控制	等级
共享网关令牌尚未升级为每用户 OIDC 会话	令牌摘要、常量时间校验、同源代理、资源归属校验	中
SQLite 只验证单实例并发语义	WAL、事务、条件更新、16 路并发确认测试	中
上下文留存与删除策略较简化	30 分钟内最近 6 条、敏感输入脱敏、会话隔离	中
外部审计消费者与 SIEM 未接入	统一 Trace、事务内审计、资源级访问控制	低
幂等最终响应失败进入 degraded	保留 pending 记录、返回原业务结果、禁止伪装失败	低

> 风险结论：高风险未缓解项 0；中风险 3 项；低风险 2 项。远程工具、平台 Webhook、真实商户和高可用属于后续外部集成前提，当前未启用的能力不作为已暴露攻击面。

仓库

github.com/cffa-as/bankagent

13. 结论

Vaultline 的差异化不在“模型会聊天”，而在“模型不能越过银行授权边界”。

系统以受限计划编译收窄模型输出，以风险分级和动作状态机控制授权，以一次性执行门和幂等控制副作用，以业务回执和审计证明最终结果。六场景共享同一控制链，使自然语言能力和银行确定性边界可以同时成立。

模型提议	服务端裁决	回执证明结果
Intent + Candidate Plan	Policy + Snapshot + MFA	Ledger + Receipt + Audit
可概率化、可替换	确定性、版本化、可测试	不可编造、可追溯、可复核

当前版本已覆盖六个赛题场景、权限分级、提示注入防御、动作快照、MFA、幂等、审计、异常熔断、运行中断、人工接管和安全撤销。后续工作应集中在生产身份、远程工具对账、高可用和真实银行业务接入。